

Task 5

Recent Malware Incidents

Operation ForumTroll — Google Chrome zero-day (CVE-2025-2783)

Timeline: Kaspersky GReAT detected targeted Chrome exploitation in late March 2025.

Google acknowledged CVE-2025-2783 and released an out-of-band patch within days.

Exploitation remained targeted toward high-value espionage victims.

Attack chain: targeted reconnaissance; spear-phishing with personalized links; victim opens link and a malicious page triggers a Mojo IPC sandbox-escape vulnerability in Chrome; post-exploit loader installs a stealer or remote access tool; data staging and exfiltration.

Public IOCs (summarized): example malicious domains conf-forum[.]net and pressinvitation[.]info; sample exploit loader SHA256 referenced by vendors; C2 pattern using CDN-style hostnames such as cdn-static-[random].azurefd.net/api/v2/collect.

Playbook (words): update all Chrome installations immediately and enforce automatic browser updates; block the listed malicious domains at perimeter DNS and proxy controls; hunt endpoints for unusual child processes spawned by chrome.exe and for browser processes making outbound connections to the CDN-style C2 pattern; review browser history and proxy logs for visits to the malicious lure pages; reset credentials and enable multifactor authentication for accounts that may have been accessed; add Yara or EDR rules based on vendor indicators and share telemetry with your CERT.

Oracle Cloud SSO / LDAP records exfiltration claim (March 2025)

Timeline: threat intelligence firm reported around 6 million alleged Oracle Cloud SSO/LDAP records for sale on March 21, 2025. Oracle investigated and customers began precautionary rotations and audits. Follow-up reporting validated some evidence while vendor investigations continued.

Probable attack chain: misconfigured SSO or LDAP endpoints or compromised administrative credentials allowed access to keystores and encrypted SSO artifacts; attacker exported JKS/JPS files, tokens, and tenant metadata; artifacts could be reused for lateral movement or token replay.

Public IOCs (summarized): sample filenames and some hashes published by researchers in

follow-up posts; no single public CVE tied at time of reporting; specific tenant artifacts referenced in validation.

Playbook (words): assume authentication artifacts may be compromised until proven otherwise; rotate keys, certificates, and keystores (JKS/JPS); invalidate and reissue SSO tokens and API keys; review administrative access logs and API call patterns for anomalous activity including logins from unusual IPs and unexpected service principal usage; shorten token lifetimes and enforce hardware-backed keystores where possible; coordinate with Oracle support, your vendor security contacts, and national CERT for guidance.

United Natural Foods, Inc. (UNFI) cyber incident (June 2025)

Timeline and impact: UNFI disclosed unauthorized activity in early June 2025 and took systems offline to contain the incident. Order processing and deliveries were disrupted, affecting retail supply chains and causing operational impacts for grocery partners. The company engaged forensic responders and law enforcement.

Attack characteristics: unauthorized access to distribution and ordering systems consistent with ransomware or disruptive supply-chain intrusion; rapid system isolation suggests containment to prevent spread or further exfiltration; public filings withheld granular IOCs.

Playbook (words): activate incident response and business continuity plans; isolate affected networks and systems; engage third-party incident responders and law enforcement; communicate with customers and partners with prioritized operational workarounds; restore core services from verified backups after integrity checks; rotate credentials used by affected systems; review and improve network segmentation to separate order management, warehouse control systems, and corporate networks; run tabletop exercises to rehearse manual fallback processes for critical operations.

Developer supply-chain campaign — malicious npm packages and social engineering (2025)

Overview: threat actors posed as recruiters or hiring managers and lured developers with fake technical tests or assignments that required installing provided npm packages. Malicious packages executed post-install actions that installed loaders or stealers, targeting developer machines and CI/CD pipelines. Registries and researchers removed many malicious packages.

Attack chain: social-engineering outreach on LinkedIn, Telegram, Discord; candidate asked to run or install an npm package; package executes post-install scripts to drop a loader or exfiltrate environment variables and secrets; stolen secrets enable access to code repositories, CI systems, and production resources.

Public IOCs (summarized): lists of flagged package names and removed registry entries published by security researchers; loader families referenced in reporting include names such as XORIndex and BeaverTail in vendor writeups.

Playbook (words): never run untrusted packages or post-install scripts on developer workstations; use disposable sandbox environments to evaluate unknown code; harden CI pipelines by enforcing dependency allowlists, restricting which external packages can run during builds, and using reproducible builds; perform secret scanning in repositories and CI logs and rotate any exposed secrets immediately; enable MFA for code hosting and CI service accounts; maintain an SBOM and monitor for sudden or unexpected dependency additions; remove compromised packages from build caches and package registries.

CLOP ransomware campaign and exploitation of managed file transfer products (Q1–2025)

Trend context: CLOP remained a high-impact extortion group in 2025, exploiting vulnerabilities in managed file transfer and enterprise software to achieve broad reach and perform data exfiltration for double extortion.

Attack patterns: reconnaissance to find widely deployed MFT or enterprise web consoles; exploit unpatched vulnerabilities or abused authentication to gain remote code execution or admin access; use stolen credentials, web shells, or remote access to move laterally, exfiltrate data, and deploy ransomware; target backups and shared storage to maximize disruption.

Public IOCs (summarized): vendor advisories published CVE references and indicators for specific affected products; CLOP infrastructure and extortion websites were tracked in threat intelligence feeds.

Playbook (words): prioritize patching and configuration hardening for managed file transfer and enterprise applications; if immediate patching is not possible, isolate MFT services from the public internet and restrict administrative access to jump hosts and VPNs with MFA; implement network segmentation and least-privilege access for file transfer services; monitor logs for anomalous admin console logins and unusual upload activity; maintain offline tested backups and practice restore procedures; engage CERT and law enforcement for extortion and coordinated takedown assistance when data is published.

Common defensive recommendations (words): keep software and browsers updated and apply security patches promptly; enforce multifactor authentication and rotate exposed keys and credentials; harden developer and CI pipelines, restrict execution of untrusted code, and maintain SBOMs; maintain immutable, offline backups and rehearse incident response playbooks; deploy EDR/XDR telemetry and threat-hunting capabilities; participate in threat intelligence sharing and coordinate with CERTs and law enforcement during incidents.

